

VULNERABILITY REPORT

Target: report.aswinicalicut.net

Date: August 2025

1. Introduction

This penetration test was conducted to assess the security posture of the target domain report.aswinicalicut.net. The scope included network service discovery, web application testing, subdomain and directory enumeration, vulnerability identification, and security header analysis. Testing was done using Kali Linux tools including Nmap, ffuf, OWASP ZAP, curl, and others.

The goal was to identify exploitable vulnerabilities and provide actionable remediation recommendations.

2. Testing Methodology

- **Network Scanning:** Full TCP and UDP scans with Nmap to discover open ports and services. Version enumeration to detect software versions.
- **Subdomain Enumeration:** Using tools like amass, subfinder to find associated subdomains for attack surface expansion.
- **Directory Enumeration:** ffuf was used to discover hidden web directories and files.
- **Vulnerability Scanning:** OWASP ZAP was used to scan the web application for common security flaws.
- **Security Header Analysis:** Curl and manual header inspection to check for missing or misconfigured HTTP security headers.
- **Manual Analysis:** Interpretation of scan results and manual verification of key findings.

3. Subdomain Enumeration

Discovered subdomains related to the target domain include (example list):

- report.aswinicalicut.net
- cpanel.aswinicalicut.net

- webmail.aswinicalicut.net
- mail.aswinicalicut.net
- ftp.aswinicalicut.net

Importance: Subdomains often expose additional services and can be weak points for attackers if not secured. They should be tested individually.

4. Directory Enumeration (ffuf Results)

Common directories discovered on <https://report.aswinicalicut.net/> include:

- /cpanel — cPanel login interface
- /webmail — Webmail access portal
- /cgi-bin — CGI scripts directory (403 Forbidden)
- /mailman — Mailing list manager (403 Forbidden)
- /pipermail — Mailing list archives
- /controlpanel — Control panel UI

explanation: These directories expose interfaces that may allow attackers to attempt unauthorized access or find sensitive scripts. Some directories are blocked by the server, which is a positive security measure.

5. Network Services & Versions

Service	Version	Ports	Notes
Apache HTTP	Version Unknown	80, 443	Version hiding detected; version unknown, limits CVE lookup
BIND DNS Server	9.11.4-P2 (RHEL7)	53	Known CVE present (see below)
Exim SMTPD	4.98.1	25, 587	Known critical CVEs present
Dovecot	Not identified	110, 143	Version unknown, needs further enumeration

Other Ports	cpwrapped	Various	Firewall/protectons blocking banner grabs
-------------	-----------	---------	---

explanation: Services are the software running on your server that provide functions like web hosting, email, and DNS. Older versions can have security holes hackers exploit.

6. Vulnerability Analysis

6.1 BIND 9.11.4-P2 (RHEL7)

- **Issue:** CVE-2024-1737 - Resource exhaustion vulnerability leading to potential denial of service.
- **Impact:** Attackers can overload the DNS service causing it to slow down or crash.
- **Recommendation:** Upgrade BIND package to latest patched version provided by RHEL.

6.2 Exim 4.98.1

- **CVE-2025-26794:** Remote SQL injection possible with specific SQLite + ETRN configurations. Can hijack mail workflows.
- **CVE-2025-30232:** Local privilege escalation via use-after-free bug. Allows local attackers to gain admin rights.
- **Recommendation:** Patch Exim immediately or disable risky features if upgrade is delayed.

6.3 Apache HTTPd

- **Issue:** Version unknown. Older Apache versions often have vulnerabilities like directory traversal, DoS, or privilege escalation.
- **Recommendation:** Identify Apache version; update to latest secure release.

6.4 Dovecot

- **Issue:** Version unknown; older versions can be vulnerable to remote code execution or authentication bypass.
 - **Recommendation:** Enumerate exact version and patch accordingly.
-

7. Web Application Security Findings

7.1 Missing Anti-Clickjacking Header

- **Issue:** No X-Frame-Options or frame-ancestors CSP header.
- **Impact:** Attackers can embed the site in an invisible iframe to trick users into unintended actions ("clickjacking").
- **Fix:** Add X-Frame-Options: SAMEORIGIN or strict Content-Security-Policy directives.

7.2 Mixed Content (HTTPS pages loading HTTP scripts)

- **Issue:** Loading scripts like http://cdn.jsinit.directfwd.com/sk-jspark_init.php over HTTP inside HTTPS page.
- **Impact:** Attackers can intercept and alter these scripts, compromising site security.
- **Fix:** Serve all resources via HTTPS only.

7.3 Inclusion of Third-Party Scripts

- **Issue:** Inclusion of external JavaScript from untrusted domain.
- **Impact:** If third-party is compromised, attacker code can execute on your site.
- **Fix:** Avoid or strictly vet all external JS sources.

7.4 Missing Strict-Transport-Security (HSTS) Header

- **Issue:** No HSTS header detected.
- **Impact:** Users can be tricked into using unencrypted HTTP, enabling SSL stripping attacks.
- **Fix:** Enable HSTS with a long max-age and includeSubDomains directive.

8. Missing or Misconfigured HTTP Security Headers

Header	Purpose	Current Status	Recommendation
Strict-Transport-Security	Enforces HTTPS, preventing downgrade attacks	Missing	Add HSTS header with max-age=31536000; includeSubDomains
Content-Security-Policy	Controls which resources can be loaded to prevent XSS	Missing	Define strict CSP policy tailored to app

X-Frame-Options	Prevents clickjacking by disallowing framing	Missing	Add SAMEORIGIN or DENY
X-Content-Type-Options	Stops browsers from MIME sniffing, reducing XSS risk	Missing	Add nosniff
Referrer-Policy	Controls referrer info sent to other sites, protecting user privacy	Missing	Add policy such as strict-origin or no-referrer

9. Additional Observations

- Several ports are tcpwrapped, showing firewall or IDS is active—this is a good defense layer but internal service hardening is still essential.
- The firewall is identified as FortiGate 80F, providing strong perimeter security.
- The application’s directory structure includes common webmail and cPanel interfaces that need regular patching and monitoring.

10. Conclusion and Recommendations

The assessment identified several critical and high-risk issues mainly due to outdated software and missing web security controls. Immediate actions to improve security posture include:

- **Update all software** — especially BIND and Exim — to latest secure versions to patch known CVEs.
- **Identify Apache and Dovecot versions** and apply necessary patches or upgrades.
- **Implement HTTP security headers** (HSTS, CSP, X-Frame-Options, X-Content-Type-Options, Referrer-Policy) to defend against common web attacks.
- **Eliminate mixed content** by serving all resources over HTTPS only.
- **Avoid untrusted third-party scripts** or ensure they come from reliable, secure sources.
- **Regularly scan and monitor** your network and web apps to detect emerging threats.

These steps will significantly reduce the risk of compromise and improve the security resilience of report.aswinicalicut.net.

11. References

- CVE-2024-1737 (BIND): <https://access.redhat.com/security/cve/CVE-2024-1737>
 - CVE-2025-26794 (Exim): <https://nvd.nist.gov/vuln/detail/CVE-2025-26794>
 - CVE-2025-30232 (Exim): <https://nvd.nist.gov/vuln/detail/CVE-2025-30232>
 - OWASP Secure Headers Project: <https://owasp.org/www-project-secure-headers/>
 - Apache HTTP Server Security: https://httpd.apache.org/security_report.html
-